NeuroShield API

Аналитический отчёт: объяснимая оценка риска мошенничества в переводах. Исследовательский прототип.

Главный вывод. На синтетическом тестовом периоде (13 909 переводов, 283 мошеннических) гибридная модель NeuroShield достигла ROC-AUC 0,990 и PR-AUC 0,879 против 0,857 и 0,185 у набора из 8 правил. При равном recall (66,8%) доля ложных тревог снизилась с 4,78% до 0,07% (в 65 раз). Данные синтетические, поэтому результат подтверждает работоспособность подхода, но не эффективность в реальном банке. В экономической модели закладывается гораздо меньший эффект.

1. Задача и решение

Правила плохо видят переводы, которые клиент делает сам под давлением мошенника, и сети мулов, а их ужесточение бьёт по честным клиентам. NeuroShield объединяет четыре независимых сигнала: транзакционные признаки, отклонение поведения клиента от его *собственной* нормы (только с согласия), структуру графа переводов и признаки социальной инженерии (минимум два независимых сигнала). Обученная модель (градиентный бустинг) совмещает их в оценку риска 0–100. Политика выбирает действие: LOW — разрешить, MEDIUM — дополнительное подтверждение, HIGH — проверка аналитиком (временное удержание — только по политике банка). Каждое решение объясняется групповой окклюзией и записывается в журнал аудита.

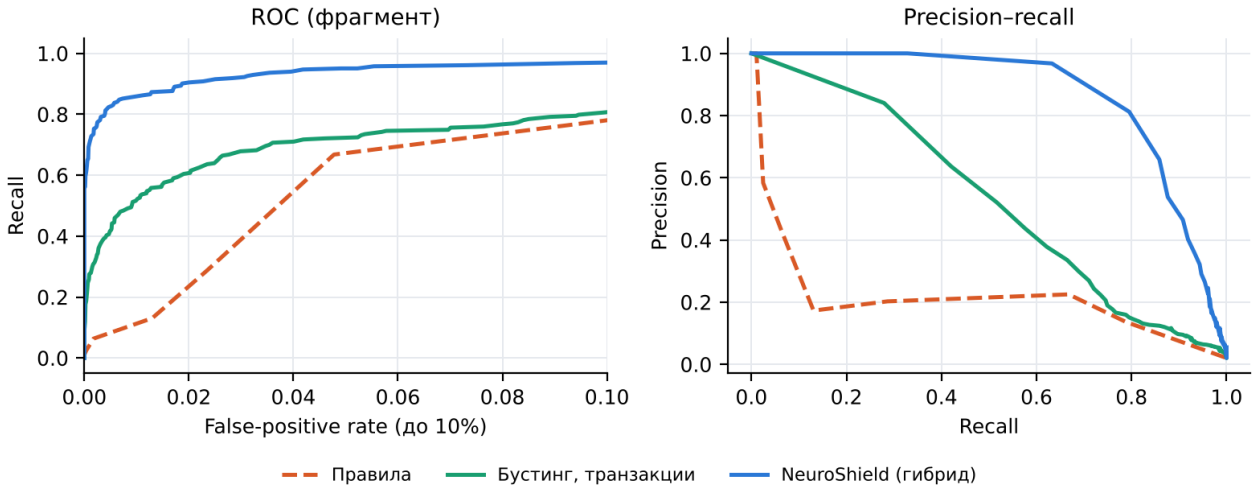
Реализация: REST API (Starlette + Pydantic), SQLite, NetworkX, React-дашборд из 8 страниц на том же порту; 45 автотестов и сквозная UI-проверка в браузере. Признаки считаются одним и тем же кодом при обучении и в API; паритет проверяет тест.

2. Данные и методика

Синтетический генератор (seed 42) моделирует 90 дней банка: 3 000 клиентов, ~145 тыс. операций; мошенничество трёх типов (захват аккаунта, социальная инженерия, пересылка через мулов) и девять типов «необычного, но честного» поведения. Все признаки считаются только из прошлого; жалобы на мошенничество приходят с задержкой 6–120 ч. Разбиение по времени: разогрев (дни 0–6), train (45 943), validation (13 293), test (13 909); доля мошенничества в тесте — 2,03%. Модель и все пороги выбраны на validation; test использован один раз. Сравнивались 6 систем. В ходе работы найден и исправлен баг генератора (окно «24 часа» считало 24 дня); все результаты получены после исправления.

3. Результаты

Система	ROC-AUC [95% CI]	PR-AUC [95% CI]	FPR при recall правил
A. Правила (8 правил)	0,857 [0,832–0,880]	0,185 [0,151–0,224]	4,78%
B1. Лог. регрессия, транзакции	0,934 [0,923–0,945]	0,410 [0,360–0,468]	5,69%
B2. Бустинг, транзакции	0,946 [0,935–0,957]	0,537 [0,485–0,596]	2,73%
C1. Лог. регрессия, гибрид	0,983 [0,977–0,988]	0,768 [0,727–0,809]	0,48%
C2. Случайный лес, гибрид	0,983 [0,973–0,992]	0,850 [0,814–0,884]	0,09%
C3. Бустинг, гибрид (NeuroShield)	0,990 [0,985–0,994]	0,879 [0,842–0,912]	0,07%



Политика balanced на тесте: уровень MEDIUM и выше ловит 85,9% мошенничества при FPR 1,04%; уровень HIGH имеет precision 91,6% при FPR 0,14%. Калибровка: ECE 0,0018. Задержка p95: модель 6.1 мс, полный HTTP-запрос с объяснением 15.7 мс (2 vCPU Xeon, последовательные запросы). Deletion-тест объяснений: удаление главного фактора снижает log-odds на 4.19 против 1.16 для случайного фактора.

4. Вклад компонентов и устойчивость

Модель	PR-AUC (test)
Полная гибридная	0,879
без поведенческого компонента	0,822
без графового	0,832
без социальной инженерии	0,861
без репутации получателя	0,857

Прогон	Правила PR-AUC	Бустинг (транз.)	Гибрид PR-AUC	Снижение FPR
default_seed42 (main)	0,185	0,537	0,879	98.5%
default_seed43	0,204	0,297	0,850	92.9%
default_seed44	0,095	0,435	0,808	98.8%
hard_seed42	0,185	0,537	0,850	97.5%
scarce_seed42	0,184	0,533	0,822	97.1%
low_reports_seed42	0,116	0,497	0,862	99.3%

hard — слабее стресс-сигнал и жертвы реже признаются; scarce — согласие на телеметрию у 30% клиентов; low_reports — в жалобы попадает 30% мошенничества плюс 200 ложных жалоб. Гибрид во всех прогонах выше модели только на транзакциях.

5. Честные клиенты с необычным поведением

Сегмент (test)	NeuroShield: step-up и выше	Правила: флаг
big purchase	3,0%	68,7%
travel	0,4%	10,7%
new device	3,5%	7,1%
new recipient	1,4%	6,3%
habit change	3,7%	2,5%
no telemetry	1,9%	2,8%
young recipient	9,1%	1,1%

Слабое место и что сделано. Честные переводы на счета младше 30 дней эскалировались заметно чаще, чем у правил. Разбор показал две ошибки измерения, обе исправлены: (1) путь по экрану при добавлении нового получателя сравнивался с нормой клиента для переводов знакомым — теперь только с той же экранной сценой и минимум 3 сессиями, иначе метрика помечается как несопоставимая; (2) «пересылкой» считались и траты в магазинах — теперь только переводы на счета в диапазоне 60–130% полученного. Вариант модели без возраста получателя отклонён правилом, заданным заранее на validation. Оставшийся разрыв — выбор политики:

Политика (test, счета < 30 дней)	Ложные тревоги	Recall по ним	Recall в целом
Правила (baseline)	2,1%	—	66,8%
NeuroShield, общий порог (по умолчанию)	9,0%	95,8%	85,9%
NeuroShield, отдельный порог (опция)	1,6%	89,6%	84,8%

Отдельный порог выбран на validation (минимум ложных тревог при потере не более 2 п.п. recall), но на тесте стоит 3 пропущенных мошенничества из 48. Поэтому он доступен в настройках и выключен по умолчанию: это решение банка.

6. Стресс-тесты: хитрый мошенник и нагрузка

На 283 мошенничествах тестового периода мошенник по очереди скрывает один сигнал; признаки пересчитываются, честный трафик не меняется. Это проверка «что если» на синтетике, а не измеренная атака.

Что скрывает мошенник	NeuroShield recall	Правила recall
ничего	85,9%	66,8%
Спокойное поведение (как обычно)	74,2%	66,8%
Нет звонка и признания	83,4%	66,8%
Своё устройство и регион	83,4%	65,0%
Старый счёт мула (+1 год)	75,6%	66,8%
Мул без жалоб	73,5%	24,4%
Медленная сеть мулов	80,6%	66,8%
Обычные суммы	78,8%	53,7%
Только днём	83,4%	65,0%
Всё сразу	1,1%	1,1%

Ни один отдельный сигнал не является единой точкой отказа. Скрыть всё сразу — значит сделать перевод неотличимым от честного; такой перевод не увидит ни одна система.

Нагрузка (POST /risk/score с объяснением, клиент и сервер на одной машине, 2 vCPU): один процесс — до 91 запросов/с, p95 14.6 мс при одном клиенте; два процесса — до 169 запросов/с, ошибок нет. Найдена и устранена транспортная задержка ~44 мс в режиме

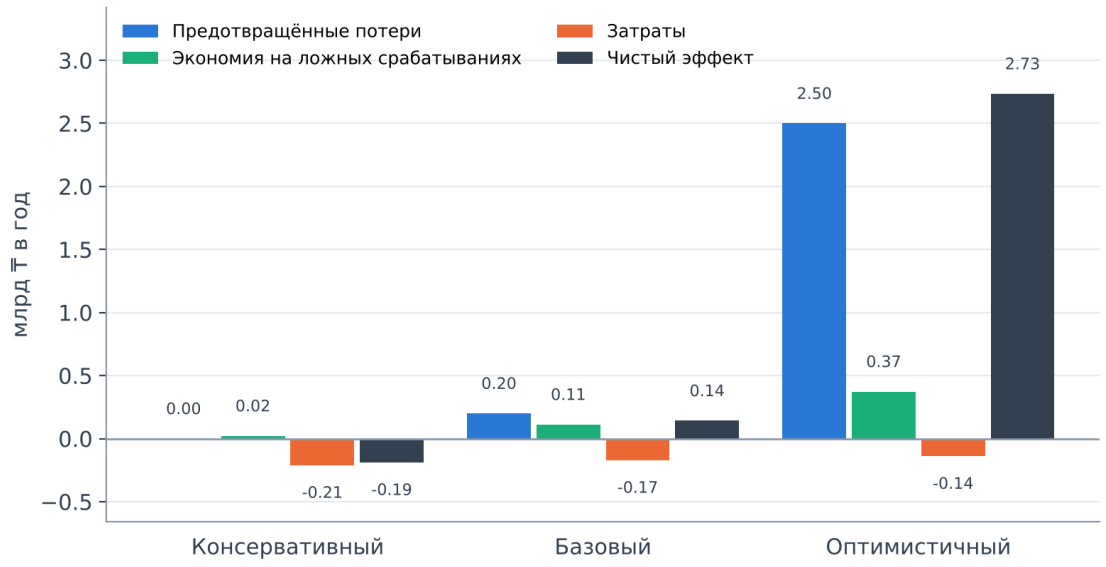
двух процессов (uvicorn создавал сокет без TCP_NODELAY); на неё есть регрессионный тест.

Обучение на примерах обхода (не принято): копии обучающих мошенничеств со скрытым сигналом подняли recall на знакомых приёмах (78,0% → 81,0% на тесте), но не на незнакомых (80,2% → 77,9%). Правило, заданное заранее на validation, отклонило модель: устойчивость нужно строить новыми независимыми сигналами.

7. Экономическая модель

Net Benefit = предотвращённые потери + экономия на обработке ложных срабатываний − инфраструктура − интеграция (амортизация 3 года) − эксплуатация. Параметры банка — сценарные допущения. Правилам дана та же многоуровневая обработка, что и модели, поэтому засчитывается только вклад самой модели. Синтетическое снижение FPR (98,5%) в расчёт не переносится: используются 20–60%.

Показатель, в год	Консервативный	Базовый	Оптимистичный
Переводов	20 млн	50 млн	100 млн
Доля мошенничества	0,02%	0,05%	0,10%
Снижение FPR моделью (допущение)	20%	35%	60%
Предотвращённые потери	0,00 млрд ₸	0,20 млрд ₸	2,50 млрд ₸
Экономия на ложных тревогах	0,02 млрд ₸	0,11 млрд ₸	0,37 млрд ₸
Затраты	0,21 млрд ₸	0,17 млрд ₸	0,14 млрд ₸
Чистый эффект	-0,19 млрд ₸	0,14 млрд ₸	2,73 млрд ₸



Безубыточность базового сценария: снижение FPR правил не менее 51,5% без прироста recall, или прирост recall на 4.3 п.п. без снижения FPR, или объём не менее 27 млн переводов в год. Консервативный сценарий (20 млн переводов) не окупается: фиксированные затраты превышают выгоду. Модельные метрики сами по себе не доказывают экономию.

8. Безопасность, приватность, ограничения

Строгая валидация входа, лимиты размера запроса и пакета, rate limit, CSP и заголовки безопасности, журнал аудита решений и изменений политики. Персональные данные не используются: только псевдонимные ID (не признаки модели) и агрегаты поведения.

Поведенческий компонент работает только при согласии, отсутствие данных не заменяется догадками, а одно лишь необычное поведение не может привести к уровню HIGH. Прототип не сертифицирован (PCI DSS, ISO 27001) и не подключён ни к одному банку.

Ограничения: синтетические данные, отражающие допущения генератора; компромисс по счетам младше 30 дней; устойчивость к новым приёмам обхода; проверка на реальных данных банка; отчёт аналитика шаблонный (без LLM).

9. Дорожная карта

Этап	Цель	Критерий перехода
1. Данные и baseline	повтор методики на истории банка против его реальных правил	PR-AUC выше правил с непересекающимися CI; FPR −30% при равном recall
2. Shadow mode	оценка живого трафика без влияния на платежи (3 мес.)	p99 < 100 мс; стабильные метрики; FPR по сегментам не хуже правил
3. Пилот	step-up для части клиентов, A/B против контроля	значимое снижение потерь или нагрузки; жалобы не выше контроля
4. Rollout	расширение после security review и согласования с регулятором	SLO выполнены 2 месяца подряд
5. Мониторинг	дрейф признаков и схем мошенничества	переобучение при падении PR-AUC > 10% или PSI > 0,2

Воспроизведение: scripts/bootstrap.sh --full пересоздаёт данные, обучает модели, считает все метрики и этот отчёт (python -m scripts.economics, python -m scripts.make_report_pdf). Исходные результаты — в experiments/results/*.json.